

4Geeks Academy

Bootcamp Ciberseguridad

INFORME PLAN DE RESPUESTA A INCIDENTE DE
RANSOMWARE BASADO EN NIST

Autor:
Harrison Hurtado Rocha

Septiembre 2026

Identificación de los sistemas críticos y activos de información de Techco

Activos	Importancia a Nivel Operativo	Vulnerabilidades
Servidor de archivos	Crítico	administración del servidor, actualizaciones y parches de seguridad, control de acceso
Base de Datos de clientes	Crítico	administración de la base de datos, actualizaciones y parches de seguridad, control de acceso
Sistemas Backup	Crítico	cifrado de backup, falta de inmutabilidad de copias de seguridad, carencia de implementación del sistema 3-2-1 de respaldos
Computadores de Empleados	crítico	malware, parcheo y actualizaciones, acceso a equipos externos, acceso libre a internet, usuario malintencionado, falta de reguladores de corriente o UPS, falta de mantenimiento

Protección de los Sistemas de Información de Techco

- **Gestión de Actualizaciones y Parcheo:** los administradores de sistema de la empresa Techco deben instalar las actualizaciones y parches de seguridad siguiendo el sistema N-1 en el que se tiene la penúltima actualización mientras se valida la última.
- **Administración eficiente del Sistema:** debido al tipo de negocio ejercido por la empresa es vital importancia reforzar la aplicación de Hardening estricto para reducir la superficie de ataque en los sistemas, implementar cortafuegos de próxima generación (NGFW) para controlar eficazmente el tráfico en la red
- **implementación de zona desmilitarizada y segmentación de la Red:** se recomienda reestructurar la red actual, debido a que tiene fallas notables y

críticas para la seguridad de la información y estructuralmente está expuesta a la propagación rápida de cualquier tipo de virus.

Teniendo en cuenta lo anterior se debe implementar los servidores en Zona Desmilitarizadas para aislarlos completamente de la red interna con el fin de proteger los recursos y la información vital para la operación del negocio.

Adicionalmente, la segmentación de la red nos permite monitorear el tráfico entrante y saliente con mayor eficacia.

- **Control de Acceso:** debe ser obligatorio el uso de (MFA)múltiple factor de autenticación en todos los ordenadores de los empleados vinculados a la empresa, y se debe controlar el cumplimiento estricto de la política corporativa de contraseñas.
- **Control de Respallos de Información:** implementar el sistema de respaldos 3-2-1: realizar 3 copias de seguridad de la información distribuidas en 2 medios de almacenamiento distintos(1 se almacenará en un disco interno y 1 en un disco externo que se encuentra en otra ciudad), y 1 copia fuera del lugar principal o en un servicio de almacenamiento en la nube. a estas copias de seguridad se les realizará validación para verificar que la restauración se ejecute sin problemas.
- **Confidencialidad de Backup:** Todas las copias de seguridad se almacenarán cifradas en origen y destino para evitar la fuga de información en caso de interceptación o robo físico del medio.
- **Implementación de Reguladores de Corriente:** realizar adquisición de reguladores de corriente o UPS que nos permitan proteger los equipos de fluctuaciones de energía y a su vez brindar un periodo de funcionamiento después que se haya presentado un problema de falta de energía.
- **Restricciones de navegación:** se implementarán controles en la navegación de los empleados con el fin de bloquear páginas que sean potencialmente peligrosas para el sistema.
- **Malware:** se debe implementar software antimalware como antivirus o EDR/XDR para prevenir y mitigar cualquier infección.

Detección de Incidente de seguridad

Para la detección de este tipo de ciberataque ocurrido en Techco en donde un empleado descargo un ransomware y afecto de manera critica los sistemas principales para la operación del negocio pudo haber sido controlado y mitigado por los siguientes sistemas que hacen parte de un conjunto de herramientas y procedimientos para estructurar un buen sistema de defensa:

- **Sistema de Gestión de Información y Eventos de Seguridad (SIEM):** la aplicación de este sistema nos permite monitorear todos los logs de los servidores y bases de datos en tiempo real y responder a alertas automáticas para que el equipo de seguridad actúe antes de que ocurran daños mayores. adicionalmente facilita el cumplimiento de normas, auditorías y reportes exigidos por regulaciones de protección de datos.
- **protección perimetral IDS/IPS:** instalar este sistema perimetral de seguridad nos proporciona la capacidad de analizar a profundidad el contenido de los datos y bloquear de manera oportuna cualquier anomalía detectada, su principal ventaja es la capacidad que posee para cerrar conexiones, descartar paquetes maliciosos o configurar el firewall de forma automatizada.
- **Protección EDR/XDR en Ordenadores de Empleados:** la implementación de esta avanzada tecnología permite detectar, investigar y responder de forma automatizada a amenazas que los antivirus tradicionales no alcanzan a ver. se enfoca solo los equipos o dispositivos finales permitiendo analizar comportamientos extraños o anomalías mediante inteligencia artificial y permite aislar el equipo afectado.
- **Capacitaciones para los empleados de la empresa:** educar a los empleados y a toda persona que tenga acceso a los activo de información en areas claves como:
 - 1) **Phishing:** Enseña a reconocer correos falsos, remitentes extraños y urgencias engañosas.
 - 2) **Contraseñas:** Fomenta el uso de claves largas, combinadas y únicas para cada sistema.
 - 3) **Doble factor (MFA):** Explica cómo activar y usar la autenticación multifactor en todas las cuentas de trabajo.
 - 4) **Enlaces y archivos:** Advierte sobre el peligro de descargar documentos o hacer clic en links desconocidos.

Respuesta a Incidente de seguridad

El plan de respuesta al incidente de seguridad presentado en la empresa Techco tiene como objetivo principal reducir los daños, limitar las interrupciones del negocio y prevenir futuros eventos. para tal fin se establece el siguiente procedimiento enfocado en ciberataque Ransomware y el cual se debe llevar a cabo de forma inmediata luego de ser detectado el ataque:

1) Contener los mecanismos técnicos del ataque de ransomware, incluyendo:
Reducir cualquier actividad maliciosa adicional aislando de la red todos los sistemas o cuentas comprometidos, o aplicando controles de acceso estrictos para detener cualquier acceso malicioso posterior a los datos.

Responsables: Gerente de Seguridad de la Información, CIRT de TI Central, CIRT

2) Aplicar reglas para bloquear el tráfico sospechoso detectado que sale de la red.

Responsables: Gerente de Seguridad de la Información, CIRT de TI Central

3) Asegurar copias de los sistemas infectados y del malware para su posterior investigación, si esto aún no se ha realizado.

Responsables: Gerente de Seguridad de la Información, CIRT de TI Central

4) Salvaguardar los activos críticos para prevenir daños adicionales o el robo de datos.

Responsables: Gerente de Seguridad de la Información, CIRT de TI Central

5) Desarrollar medidas de protección derivadas de los resultados del análisis del código malicioso, es decir Posibles opciones de contención (p. ej., basadas en información disponible públicamente sobre *ransomware* conocido) para proteger la infraestructura contra dicho código y otros ransomwares que puedan intentar infectar utilizando el mismo mecanismo.

Responsables: Gerente de Seguridad de la Información, CIRT

6) Debido a que se trata de un ataque por correo electrónico:

Se debe bloquear al remitente y el mensaje marcándolo como spam, Bloquear la dirección IP identificada en el encabezado del correo electrónico.

Responsables: Gerente de Seguridad de la Información

7) Bloquear el acceso a cualquier herramienta de acceso remoto (RAT) identificada para evitar la comunicación con servidores de comando y control, sitios web y aplicaciones explotadas.

Responsables: Gerente de Seguridad de la Información, CIRT de TI Central

9) Obtener copias del código malicioso, de los sistemas afectados y de cualquier artefacto identificado para su posterior investigación (recurriendo a soporte forense si se requieren copias forenses).

Responsables: Gerente de Seguridad de la Información, CIRT de TI (Equipo central)

10) Contener los efectos del ciber incidente en el negocio:

Implementar la estrategia de notificación, incluyendo las notificaciones internas o externas, así como la comunicación a empleados, terceros, proveedores de servicios y clientes.

Responsables: Gerente de Seguridad de la Información, CIRT de TI (Equipo central).

Recuperación y Continuidad del Negocio

En esta fase el objetivo principal es restablecer los sistemas y servicios afectados a su funcionamiento normal tras el ataque de Ransomware ocurrido, mediante la ejecución de las siguientes acciones concisas que permitan reanudar la operación de la empresa garantizando la seguridad de la información y los recursos implicados en el negocio.

1) Restaurar Información desde copias de seguridad (*backups*) que estén libres de códigos maliciosos o alteraciones, además de los sistemas en red afectados y servicios suspendidos

2) Reconstruir sistemas, Reinstalar o formatear máquinas y servidores dañados cuando se garantice su limpieza total.

3) Realizar Aplicación de parches de seguridad, Actualizaciones de software y cerrar las brechas de seguridad que permitieron el ataque de Ransomware en los servidores que brindan los servicios en la nube.

4) Restablecer contraseñas de usuario y claves de acceso pertenecientes a los empleados, además de reforzar los métodos de autenticación implementando MFA para evitar robo de credenciales y usurpación

5) Apoyar la elaboración de comunicaciones externas proporcionando mensajes sencillos y precisos, coherentes con las actividades de remediación técnica.

6) Establecer mecanismos de monitoreo en la red para verificar presencia de firmas y otros indicadores de compromiso para evitar que el ataque de *ransomware* vuelva a producirse.

Mejora Continua de los Sistemas de Información

- **Revisión post-incidente:** Realizar una reunión con el equipo de TI y con directivos de alta gerencia de Techco para analizar sucesos y preguntas como: qué pasó y porque el empleado abrió el correo malicioso, cómo se respondió una vez se detectó el ransomware y qué falló en el proceso de detección y contención del incidente.
- **Actualización de documentación:** Modificar los planes de respuesta ante incidentes, los manuales operativos de sistemas corriendo y los diagramas de contacto con base en la experiencia.
- **Monitoreo de parches y actualizaciones:** realizar verificación de parcheado de vulnerabilidades y actualizaciones de software realizadas. con el fin de evaluar la efectividad y el rendimiento de estas.
- **Evaluación de Backups:** Realizar verificación de la restauración de copias de seguridad para asegurarse de que no sufran daños a la hora de ser cargadas en el sistema nuevamente.
- **Cumplimiento de Políticas de Contraseñas:** evaluar el cumplimiento general de las políticas de uso de contraseñas seguras por parte de todos los empleados de Techco.
- **Implementación de Auditorías Externas:** realizar la implementación de auditorías por parte de una organización externa acreditada para tal fin, con el objetivo de evaluar de manera rigurosa políticas internas de seguridad, sistemas en operación, sistemas de protección perimetral, sistemas de monitoreo del tráfico y cumplimiento de los empleados con buenas prácticas asociadas a la seguridad de la información